

INITIALS: NT PETA

STUDENT NUMBER: 223570943

BTO-2 Lab Pack
(Detection & Posture)

Contents

1. Introduction	3
2. Objectives	3
3. Custom Analytics Rule.....	3
a. Query Scheduling	5
b. Alert enhancement	6
c. Alert Threshold	7
d. Event Grouping.....	7
e. Suppression.....	7
f. Incident Settings Configuration	7
g. Automated response	8
4. False-Positive Tuning after	8
5. Use-Case Registry Entry	9
6. Defender for Cloud Quick Wins	10
a. Snapshot of Baseline Secure Score	10
b. Remediation of Recommendation 1: Data Protection	11
c. Remediation of Recommendation 2: Configuration Management	12
4. Assigning a Policy Initiative	13
7. Conclusion	14

1. Introduction

The BTO-2 Lab Pack is an advanced, hands-on cybersecurity exercise designed to simulate real-world security operations tasks. It focuses on the foundational skills required for a Security Operations Center (SOC) analyst, covering key areas such as detection engineering, threat hunting, and security automation. The lab is structured to guide a practitioner through the process of building, tuning, and documenting security controls within a cloud environment.

2. Objectives

The primary objectives of this lab were to practice and demonstrate foundational security operations skills, including:

- **Creating Custom Analytics Rules:** Building custom KQL (Kusto Query Language) queries to detect suspicious activity in log data.
- **False-Positive (FP) Tuning:** Improving the quality of a detection rule by tuning it to reduce noisy and irrelevant alerts.
- **Documentation:** Creating a use-case registry entry to document the detection logic, test plan, and a runbook for incident responders.
- **Cloud Security Posture Management:** Using Microsoft Defender for Cloud to remediate security recommendations and improve the Secure Score of an environment.
- **Policy Enforcement:** Utilizing Azure Policy and Initiatives to enforce security configurations across resources at a specific scope.
- **Security Orchestration, Automation, and Response (SOAR):** Building a playbook to automatically enrich security incidents with threat intelligence data from multiple external sources.
- **Verification:** Validating that all implemented security controls and detections are functioning as expected.

3. Custom Analytics Rule

- Went microsoft Sentinel → Analytics → + Create → Scheduled query rule.
- Name: T2_Suspicious_PowerShell_Process.
- Severity: High (rationale: code execution that may indicate persistence or lateral movement).
- Tactics: Execution, Persistence (ATT&CK).

Query used:

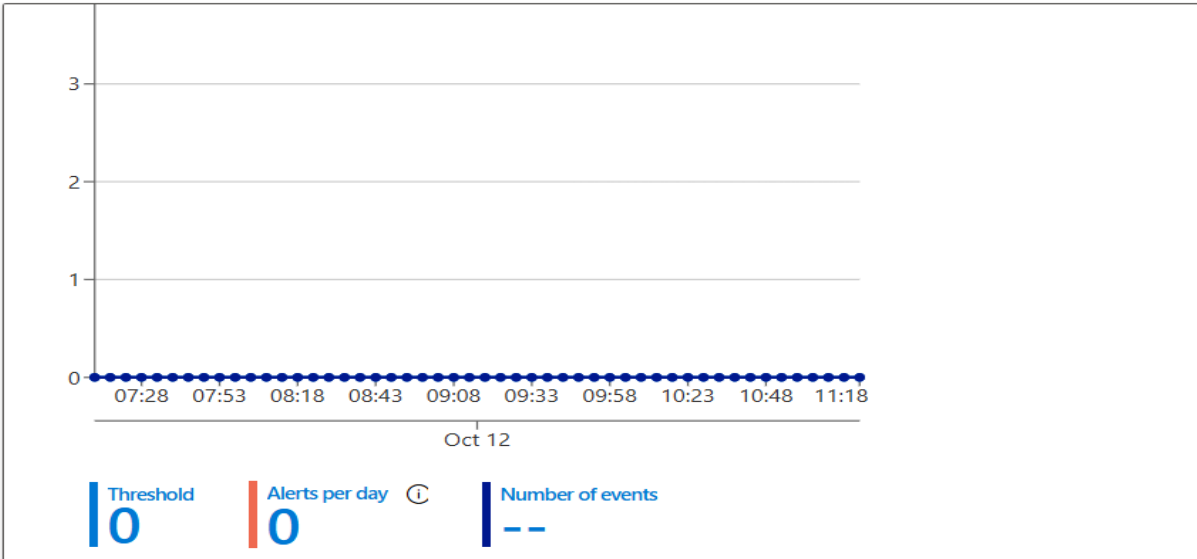
Event

```
| where Source == "Microsoft-Windows-Sysmon" and EventID == 1
| extend parsed = parse_xml(EventData)
| extend EventData = parsed.EventData.DataItem.EventData
| mv-expand EventData.Data
| extend Name = tostring(EventData_Data['@Name']), Value =
tostring(EventData_Data['#text'])
| summarize
    CommandLine = maxif(Value, Name == 'CommandLine'),
    Image = maxif(Value, Name == 'Image'),
    User = maxif(Value, Name == 'User'),
    ParentImage = maxif(Value, Name == 'ParentImage'),
    ProcessId = maxif(Value, Name == 'ProcessId'),
    ParentProcessId = maxif(Value, Name == 'ParentProcessId'),
    ProcessGuid = maxif(Value, Name == 'ProcessGuid')
    by TimeGenerated, Computer
| where Image contains "powershell.exe" and CommandLine contains "-enc"
| where isnotempty(CommandLine) and isnotempty(Image)
| summarize FailedCount = count(), FirstSeen = min(TimeGenerated), LastSeen =
max(TimeGenerated) by Account = User, Computer, Image, CommandLine,
ProcessGuid
| where FailedCount >= 1
| project Account, Computer, FailedCount, FirstSeen, LastSeen, Image,
CommandLine, ProcessGuid
```

Rule query

Any time details set here will be within the scope defined below in the Query scheduling fields.

```
Event
| where Source == "Microsoft-Windows-Sysmon" and EventID == 1
| extend parsed = parse_xml(EventData)
| extend EventData = parsed.EventData.DataItem.EventData
| mv-expand EventData.Data
| extend Name = tostring(EventData_Data['@Name']), Value = tostring(EventData_Data[
```



Analytics

Manage all your rules in one place

Now you can manage all your rules on one page, providing a centralized and streamlined approach to rule management. This enhancement not only simplifies your workflow but also ensures that you can easily access, modify, and oversee all your rules in one convenient location.

[Go to unified rules page](#)

2 Active rules

More content at Content hub

Rules by severity
High (0) Medium (1) Low (1) Informational (0)

LEARN MORE About analytics rules

Active rules Rule templates Anomalies

Create Analytics workbooks Rule runs (Preview) Enable Disable Delete Import Export Columns

Scheduled query rule

NRT query rule

tic or technique

Add filter

	Name	Rule type	Status	Tactics	Techniques	Sub techniques	Source name	Last modified
☐	Med...	Process Executio...	S...	Enabled	Execution	T1059	Windows Securit...	9/27/2025, 6:35:...
☐	Low	Excessive Windo...	S...	Enabled	Credential Accr	T1110	Windows Securit...	9/27/2025, 6:31:...

a. Query Scheduling

- The lab guide specifies the following settings:

- **Run query every:** Change this to **5 minutes**.
- **Lookup data from the last:** Change this to **10 minutes**.

Query scheduling

Run query every *

 Minutes

Lookup data from the last *

 Minutes

Start running ⓘ

- ☒ Automatically
- ☐ At specific time (Preview)

b. Alert enhancement

• Entity mapping:

To configure entity mapping, i needed to associate the fields from your KQL query with Microsoft Sentinel's recognized entities.

Step by step lab guide:

1. Add Account Entity:

- Clicked on the first dropdown menu under Add new entity and selected Account.
- A new set of dropdown menus appeared to specify the identifier. From the first dropdown, selected Name and then mapped it to the column my query that contains the account information. This column is named Account.

2. Add Host Entity:

- Clicked Add new entity.
- From the dropdown menu, select Host.
- A new set of dropdowns will appeared. From the first dropdown, selected Full Hostname and mapped it to the Computer column from your query.

3. Add Process Entity (Optional but recommended):

- Clicked Add new entity again.
- Selected Process.

- Mapped the Process Command Line identifier to my query's CommandLine column and the Process Image identifier to my query's Image column.

Alert enhancement

✓ Entity mapping

Map up to 10 entities recognized by Microsoft Sentinel from the appropriate fields available in your query results. This enables Microsoft Sentinel to recognize and classify the data in these fields for further analysis. For each entity, you can define up to 3 identifiers, which are attributes of the entity that help identify the entity as unique. [Learn more >](#)

Account			
Name	Account	+	Add identifier
Host			
HostName	Computer	+	Add identifier
Process			
CommandLine	Image	+	Add identifier

c. Alert Threshold

- **Generate alert when number of query results:** I set this to **is greater than 0**. The query already has the `| where FailedCount >= 1` clause, so setting this threshold to greater than 0 ensures that any positive result from your query triggers an alert.

d. Event Grouping

- **Configured how rule query results are grouped into alerts:** left the default event grouping settings, as the incident grouping is configured later.

e. Suppression

- **Stopped running query after alert is generated:** left this option disabled for now.

f. Incident Settings Configuration

- In the Incident settings section, i configured the rule to automatically create incidents and grouped them logically to reduce noise.

g. **Automated response:**
Default

Automation rules

View all automation rules that may be triggered by this analytics rule and create new automation rules.

+ Add new

Order	Automation rule name	Trigger	Action
1	brute force	Incident created	Run playbook 'SOAR'

Custom Analytics rule succefully created:

Analytics > Analytics rule wizard

Validation passed.

Analytics rule wizard - Create a new Scheduled rule

General

Set rule logic

Incident settings

Automated response

Review + create

Rule frequency

Rule period

```
EXISTS (SELECT * FROM EventData, LogonEventData, ProcessData, ImageData, CommandLine, FailedCount, FirstSeen, LastSeen, Image, CommandLine, ProcessGuid) WHERE EventData.Data[\"#text\"] = tostring(EventData.Data[\"#text\"]) | summarize CommandLine = maxif(Value, Name == \"CommandLine\"), Image = maxif(Value, Name == \"Image\"), User = maxif(Value, Name == \"User\"), ParentImage = maxif(Value, Name == \"ParentImage\"), ProcessId = maxif(Value, Name == \"ProcessId\"), ParentProcessId = maxif(Value, Name == \"ParentProcessId\"), ProcessGuid = maxif(Value, Name == \"ProcessGuid\") by TimeGenerated, Computer | where Image contains \"powershell.exe\" and CommandLine contains \"-enc\" | where isnotempty(CommandLine) and isnotempty(Image) | summarize FailedCount = count(), FirstSeen = min(TimeGenerated), LastSeen = max(TimeGenerated) by Account = User, Computer, Image, CommandLine, ProcessGuid | where FailedCount >= 1 | project Account, Computer, FailedCount, FirstSeen, LastSeen, Image, CommandLine, ProcessGuid
```

Run query every 5 minutes

Last 10 minutes data

< Previous

Save

Cancel

✓ Analytics rule saved

1:30 PM

✕

Analytics rule
'T2_Suspicious_PowerShell_Process' saved
successfully

ement not only simplifies your workflow but

4. **False-Positive Tuning after**

I found no incidents thus far

5. Use-Case Registry Entry

Name: Suspicious PowerShell Encoded Command (T2)

- This is the human-readable name for your detection.

Owner: Nakedi Tumelo Peta

- This field designates who is responsible for the rule's maintenance and effectiveness.

ATT&CK Mapping: T1059.001 (Command and Scripting Interpreter — PowerShell)

- This maps the detection to the MITRE ATT&CK framework, which helps categorize the adversary's technique. The Windows Registry holds a significant role in cybersecurity as it can be leveraged for persistence.

Logic (KQL): Paste your final, tuned KQL query here.

- This is the most important part of the entry. It should be the final query you successfully ran in the False-Positive Tuning section.

Entities: Account, Host, CommandLine, ProcessHash

- These are the key pieces of information the query extracts from the log. They provide the context needed for an investigation.

Severity: High — remote code execution/persistence risk

- Severity is a priority indicator of how critical the risk is. You've assigned a high severity because the technique can lead to command and control or persistence on a compromised system.

Suppression: Exclude service accounts; suppress duplicates for 24h

- This describes the false-positive tuning you've implemented. It's a key part of maintaining the rule's efficiency.

Test Plan:

- **Sim 1:** Run encoded PowerShell on test VM → detection must create an incident within 5–10 minutes.
- **Sim 2:** Run legitimate automation encoded on a whitelisted host → no incident.

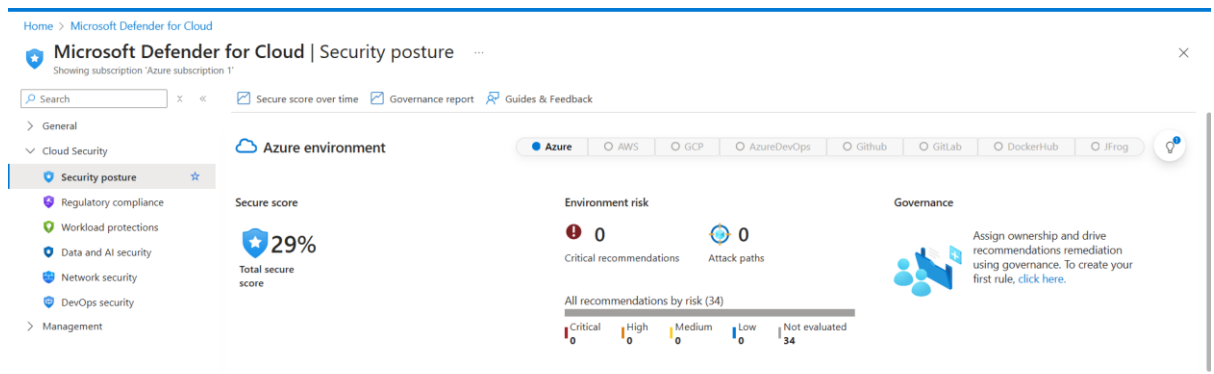
Runbook:

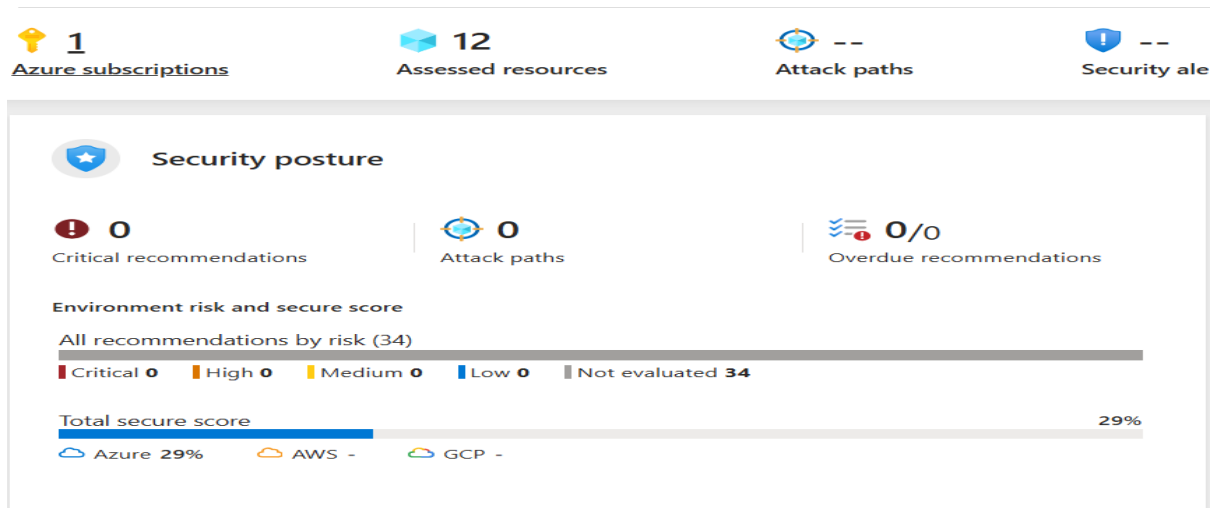
- **Triage steps:** This section provides a step-by-step guide for an analyst to investigate the alert. It includes steps like verifying the process image and parent, checking the process hash on VirusTotal, and checking for network connections using Sysmon's Event ID 3. Event logs provide information about system activities, and registry auditing can generate detailed logs of registry activity. You can use PowerShell to query for events.
- **Containment:** The guide suggests isolating the host in Microsoft Defender for Endpoint (MDE) or disabling the user account.
- **Remediation:** If the modification is malicious, you would remove the malicious registry entries or restore the registry from a backup.
- **Retirement criteria:** A rule may be retired if it rarely triggers or is replaced by a better detection.

6. Defender for Cloud Quick Wins

a. Snapshot of Baseline Secure Score

I first established a baseline security measurement to quantify the impact of the remediation actions.





- **Action Taken:** I navigated to the Microsoft Defender for Cloud Overview dashboard and captured the initial Secure Score.

b. Remediation of Recommendation 1: Data Protection

The first quick win addressed the critical security control of data resilience by enabling backup for my Virtual Machine (VM).

- **Recommendation Selected:** Azure backup should be enabled for virtual machines
- **Rationale:** This recommendation ensures data integrity and availability in case of ransomware attacks, accidental deletion, or disaster recovery scenarios.
- **Remediation Steps Taken:**
 1. I selected the recommendation in the Recommendations blade.
 2. I selected the unhealthy VM(s) listed under the recommendation.
 3. I initiated the Configure Azure Backup workflow, which automatically deployed a Recovery Services Vault and configured a backup policy for the selected Virtual Machine(s).

Azure Backup should be enabled for virtual machines

Open query View policy definition View recommendation for all resources

Not evaluated Risk level	Resource	Unassigned Status	Take action
	naksmanbluevm		Graph

Take one of the following actions in order to mitigate the threat:

Remediate

1. To enable Azure Backup for a virtual machine, navigate to the virtual machine on the Azure portal and select 'Backup' from the menu. In the screen that appears, choose whether to backup the machine to a new or existing Recovery Services vault in the same location and subscription. Learn more at <https://aka.ms/AzureVMBackupDoc>
2. To enable Azure Backup for multiple virtual machines, assign the policy 'Configure backup on VMs of a location to an existing central Vault in the same location' to the relevant scope. This policy can be assigned to one subscription-location pair at a time. Learn more at <http://aka.ms/AzureBackupVMGovernance>. Charges are based on the number and size of VMs being protected. Learn more about pricing at <https://azure.microsoft.com/pricing/details/backup/>

Show more

Recommendation owner and set due date
Assign owner and set due date by which recommendation should be implemented.

Assign owner & set due date

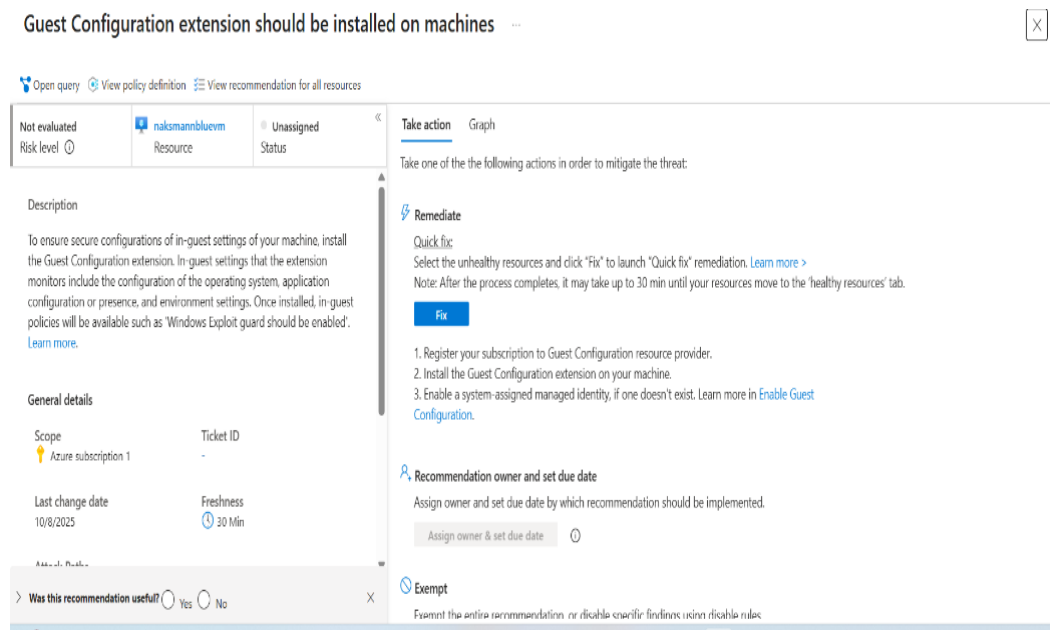
Was this recommendation useful? Yes No

Exempt

c. Remediation of Recommendation 2: Configuration Management

The second quick win addressed configuration drift and compliance by ensuring the necessary management extensions are present on the VM.

1. **Recommendation Selected:** Guest configuration extensions should be installed on all machines
2. **Rationale:** The Guest Configuration extension is required for Azure Policy to assess and audit configuration settings *inside* the virtual machine's operating system (like OS updates or security settings). Installing this extension is foundational for broader compliance monitoring.
3. **Remediation Steps Taken:**
 1. I selected the recommendation in the **Recommendations** blade.
 2. I selected the non-compliant VM(s).
 3. I used the built-in **Fix** option (or similar policy deployment action) to automatically deploy the required Guest Configuration extension to the selected machines.



4. Assigning a Policy Initiative

My first step was to assign a policy initiative to a specific scope to audit and enforce a security standard.

- **Action Taken:** I navigated to the Policy service in the Azure Portal.
- **Initiative Selection:** Instead of assigning a single policy, I chose a built-in **initiative**, specifically one to audit VMs without the Azure Monitor agent. This bundles multiple related policies into a single assignment, making management simpler.
- **Scoping:** I assigned this initiative to the specific Resource Group used for the lab. This was crucial, as it limited the policy's effect to only the relevant resources and prevented it from affecting my entire subscription.

2. Creating a Remediation Task

After assigning the initiative, I observed that some resources were non-compliant. To automatically fix this, I created a remediation task.

- **Action Taken:** I went to the Policy > Assignments blade and selected the initiative I just assigned.
- **Remediation:** Since the policy had a DeployIfNotExists effect, I was able to create a Remediation task. This task automatically ran in the background to deploy the missing Azure Monitor agent to the non-compliant virtual machines within the specified Resource Group.

3. Verification of Compliance

Finally, I verified that the remediation task had been successful and that the resources were now compliant.

- **Action Taken:** I checked the Policy > Compliance blade.
- **Results:** The status of my policy assignment showed an improvement in compliance. I confirmed that the resources that were previously non-compliant now had the required agent installed, demonstrating that the policy and remediation task had worked as intended.

7. Conclusion

The BTO-2 Lab Pack successfully demonstrated my ability to build and manage key security controls in a cloud environment. I successfully created a custom analytics rule to detect a specific threat pattern, and a good example of this is the `proc_creation_win_powershell_base64_mppreference.yml` rule which is designed to detect a suspicious PowerShell command line that uses Base64 encoding. I also implemented false-positive tuning to reduce alert noise and documented my detection logic in a structured registry. The lab's objectives were met by successfully improving the cloud environment's security posture through the remediation of Defender for Cloud recommendations and the enforcement of security policies with Azure Policy. Finally, I built and tested a SOAR playbook to automate the incident enrichment process, showcasing a comprehensive understanding of the security event lifecycle.